

Sensibilisation à l'ingénierie sociale

Formation Logiclever – Consultants, fonctions support & administratives

Version du 4/11/2025

logiclever

Objectifs de la formation

L’objectif aujourd’hui est de mieux comprendre cette menace qui cible directement l’humain, afin de vous donner les bons réflexes, aussi bien au sein de Logiclever que lors de vos missions chez nos clients.

- Comprendre le rôle central de l’ingénierie sociale dans les cyberattaques modernes
- Identifier les nouvelles méthodes d’attaque exploitant l’humain et la technologie
- Évaluer les risques potentiels et leurs impacts métier
- Appliquer des bonnes pratiques avancées au siège et en contexte client
- Réflexe clé : en cas de doute → contacter le RSSI

SOMMAIRE

01 Objectifs de la formation

02 Définition & contexte

03 Exemples concrets et Nouvelles formes d’ingénierie sociale

04 Risques potentiels

05 Bonnes pratiques

06 Conclusion & réflexes clés

Définition & contexte

Ingénierie sociale : Il s'agit d'une techniques de manipulation exploitant la confiance, l'urgence, l'autorité ou la curiosité pour pousser une personne à :

- divulguer une information sensible,
- réaliser une action compromettante (clic, ouverture de fichier, transfert),
- ou fournir un accès physique/logique.

Contrairement aux attaques purement techniques (brute-force, exploit, malware), elle bypasse la sécurité en ciblant l'humain. Elle combine souvent :

- **Psychologie** (influence, intimidation, persuasion),
- **Technologie** (phishing ciblé, deepfake, usurpation d'adresse mail, IA),
- **Contexte organisationnel et actualité** (hiérarchie, urgences métier, procédures complexes, situation de crise…).

⚠️ *80 à 90 % des attaques réussies commencent par une faille humaine exploitée via ingénierie sociale.*

Exemples concerts et nouvelles formes

Pour rendre cette menace plus tangible, voici quelques exemples :

- Email de phishing imitant un outil SaaS
- Appel d'un faux technicien demandant une réinitialisation
- Usurpation de dirigeant via deepfake audio
- Faux partenaire demandant partage de fichiers
- Faux badge utilisé pour obtenir un accès physique

Les techniques évoluent rapidement, notamment avec l'arrivée de l'IA

- Deepfakes audio/vidéo → simulation voix/visioconférence
- Phishing ciblé (spear phishing)
- Vishing (voice phishing)
- Smishing (SMS frauduleux)
- Watering hole attacks
- Exploitation des réseaux sociaux

Risques potentiels et niveaux de risque

Les impacts de l'ingénierie sociale sont variés, mais certains sont critiques : **vol de comptes, déploiement de ransomware, fraude au virement**. D'autres sont moins graves mais restent importants, comme une fuite d'informations internes ou une atteinte à l'image sur les réseaux sociaux. Nous utilisons une graduation simple : rouge pour élevé, orange pour moyen, vert pour faible.

🔴 Compromission de compte (identifiants volés)
🔴 Malware / ransomware via pièces jointes
🟠 Fuite d'informations sensibles
🔴 Accès physique non autorisé et infiltration dans l'entreprise
🔴 Fraude au président / virement frauduleux
🟢 Atteinte à l'image via réseaux sociaux

Nous voyons bien que ces situations seraient extrêmement dommageable pour notre entreprise comme pour nos clients. Heureusement un comportement adapté et un ensemble de règle d'utilisation permettent de réduire drastiquement les risques.

Bonnes pratiques

Ainsi, face à ces risques, certaines règles sont essentielles : vérifier systématiquement l'expéditeur d'un message, utiliser des mots de passe robustes et la double authentification, ne jamais partager ses identifiants, verrouiller son poste et refuser tout périphérique inconnu. **Et surtout, rappelez-vous : en cas de doute, contactez immédiatement le RSSI**. »

Lors de vos missions, vous êtes aussi responsables de la sécurité chez nos clients. Ces règles sont donc essentiels pour y travailler :

- **Respecter règles et chartes du client**
- **N'utiliser que les systèmes autorisés**
- **Refuser toute demande d'accès non validée**
- **Vigilance face aux personnes inconnues**
- **Signaler anomalies au client ET au RSSI Logiclever**
- **Se comporter en ambassadeur sécurité**

Vous êtes vus comme des ambassadeurs de Logiclever et devez donc montrer l'exemple en matière de cybersécurité. Nous allons maintenant voir quelques cas pratiques.

Mise en situation interactive

1 Analyse d'un faux email

Scénario : Vous recevez un email semblant venir de Google/Microsoft/Payfit. L'expéditeur vous demande de cliquer sur un lien pour "réinitialiser" votre mot de passe. Que faire ?

- Ne pas cliquer sur le lien ni télécharger de pièce jointe.
- Vérifier l'adresse email complète de l'expéditeur
- Rechercher les signaux faibles (fautes d'orthographe, ton pressant, logo pixelisé,etc..)
- Supprimer le mail et **signaler immédiatement l'incident au RSSI**.

👉 **Message clé** : Ne jamais se précipiter, toujours vérifier et signaler.

2 Cas « faux appel DSI client »

Scénario : Vous recevez un appel d'une personne qui se présente comme le DSI du client. Il demande en urgence votre identifiant et mot de passe pour "résoudre un problème technique critique". Que faire?

- Ne jamais communiquer identifiants/mots de passe./
- Vérifier l'identité via les canaux officiels (annuaire interne du client, Teams officiel, manager).
- Expliquer poliment que vous ne pouvez pas répondre
- **Prévenir immédiatement le RSSI**

👉 **Message clé** : Un vrai DSI ou support technique ne demande jamais un mot de passe par téléphone.

3 Badge oublié trouvé

Scénario : Dans les locaux du client, vous trouvez un badge d'accès oublié sur une table de réunion. Que faire ?

- Ne pas l'utiliser vous-même ni le conserver.
- Le remettre immédiatement à la sécurité du site ou à l'accueil selon la procédure du client.
- Informer discrètement la personne concernée si vous la connaissez.
- Signaler l'incident au **contact sécurité du client et au RSSI de Logiclever**.

👉 **Message clé** : La sécurité physique est aussi importante que la sécurité informatique.

Conclusion & réflexes clés

Rappelez vous que :

- **L’ingénierie sociale exploite l’humain et que vous êtes une cible potentiel**
- **Chaque collaborateur est un maillon de défense, nous devons donc tous être vigilant et permettre à nos collègues d’être tout aussi fiables**
- **Le réflexe en cas de doute → JE STOP → Je contact immédiatement le RSSI**
- **C’est votre responsabilité aussi de protéger nos données et celles de nos clients**